GSoC 2026 Proposal

PyGoat Add OWASP Top 10 2025 Vulnerability Labs

Organization: OWASP Foundation | Project: PyGoat
Applicant: Sankalp Ghasti | March 31, 2026

1. About Me

Full Name: Sankalp Ghasti

University: SITCOE, Maharashtra, India

Degree: BTech CSE (First Year)

Email: xyz@gmail.com

GitHub: github.com/SankalpGhasti-dev

LinkedIn: linkedin.com/in/sankalp-ghasti

OWASP Slack: SankalpGhasti

Bio:

I am a first-year BTech CSE student from Maharashtra, India with a strong focus on cybersecurity and ethical hacking. I hold an ISC2 certification and am an active Developer Community Member at NVIDIA. I am passionate about security education, open-source contribution, and building tools that help developers write more secure code.

2. Coding Skills

Platform: Windows 11, VS Code, Docker Desktop

Programming Languages:

- **Python —** Primary language. Used in all OWASP work, Django projects, automation scripts.
- **C —** Strong fundamentals. Academic projects and low-level understanding.
- **HTML/CSS/JavaScript —** Frontend development for web projects.
- **Django —** Actively used in PyGoat contribution. Views, URLs, templates, models.

PyGoat Desired Knowledge Check:

- Python — Yes (primary language)
- Django — Yes (actively used in contribution)
- Docker — Yes (set up PyGoat using Docker, fixed Dockerfile issues)
- Application Security — Yes (ISC2 certified, ethical hacking background)
- HTML/CSS/JavaScript — Yes

3. Project Setup

I have successfully set up PyGoat locally using Docker on Windows 11:

- Forked the repository: github.com/SankalpGhasti-dev/pygoat
- Fixed deprecated Debian Buster base image in Dockerfile
- Fixed psycopg2 compilation error by switching to psycopg2-binary
- Successfully built and ran PyGoat using Docker at localhost:8000
- Introduced myself on OWASP Slack in #project-pygoat and #gsoc

4. You and Us

Prior OWASP Contributions

- **OWASP Python-Honeypot —** PR #384 to OWASP Python-Honeypot (Nov 2025): Identified and removed deprecated codecov dependency with full CVE analysis referencing CVE-2019-10800 and the 2021 supply-chain compromise. This is a real A03:2025 Software Supply Chain issue.
- **PyGoat Issue #490 —** Issue #490 (Mar 2026): Identified PyGoat has no OWASP Top 10:2025 coverage and opened feature request.
- **PyGoat PR —** Added complete OWASP Top 10:2025 sidebar section with 10 vulnerability info pages (A1-A10). Each page includes description, real-world example, impact, and mitigation.

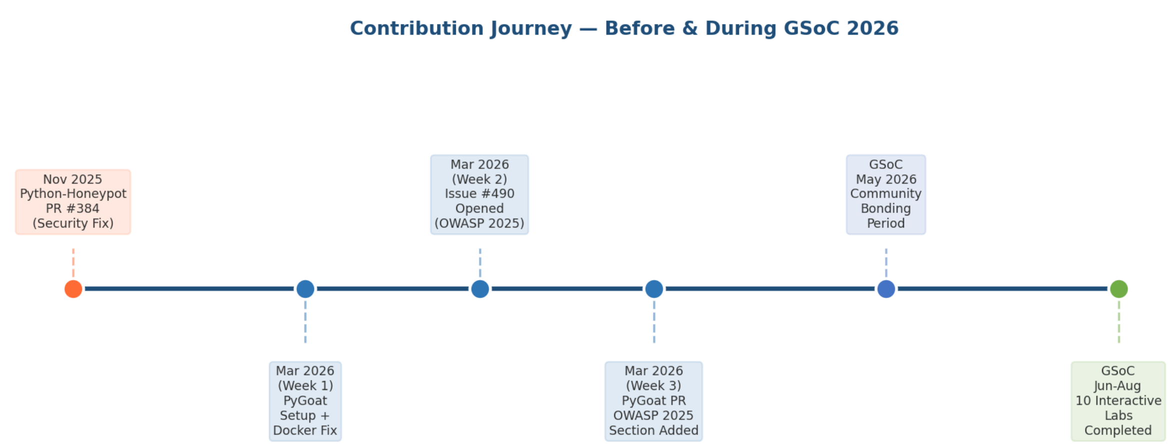

Figure 1: Contribution journey before and during GSoC 2026

Why I Chose PyGoat

My journey began when I tried to set up OWASP Python-Honeypot to study honeypots. I discovered a supply-chain vulnerability — a deprecated dependency removed from PyPI and archived. I fixed it with a full security analysis. That led me to PyGoat, where I noticed the absence of OWASP Top 10:2025 coverage. I started contributing immediately — not as a GSoC strategy, but because I genuinely wanted to improve security education tooling.

5. Your Project

Problem Statement

PyGoat covers OWASP Top 10:2017 and 2021, but the newly released OWASP Top 10:2025 has two entirely new vulnerability categories with no existing labs:

- A03:2025 — Software Supply Chain Failures (NEW) — directly connected to my Python-Honeypot PR #384
- A10:2025 — Mishandling of Exceptions (NEW)

OWASP Top 10: 2021 vs 2025

2021	2025
A01: Broken Access Control	A01: Broken Access Control
A02: Cryptographic Failures	A02: Security Misconfiguration (moved up)
A03: Injection	A03: Software Supply Chain Failures (NEW)
A04: Insecure Design	A04: Cryptographic Failures (moved)
A05: Security Misconfiguration	A05: Injection (moved)
A06: Vulnerable Components	A06: Insecure Design (moved)
A07: Auth Failures	A07: Authentication Failures
A08: Software and Data Integrity	A08: Vulnerable Components
A09: Logging and Monitoring	A09: Logging and Monitoring
A10: SSRF	A10: Mishandling Exceptions (NEW)

Proposed Solution

- Complete OWASP Top 10:2025 section in PyGoat sidebar
- 10 interactive vulnerability labs with vulnerable code, exploitation steps, and secure fix

- Special focus on A03:2025 Software Supply Chain — real-world lab based on codecov incident
- Microservice/Docker architecture for clean lab isolation
- Source code view showing vulnerable vs secure implementation

What Makes Me Suited

- Already contributing to PyGoat and OWASP Python-Honeypot
- ISC2 certified — strong security knowledge foundation
- Python and Django proficiency — PyGoat's exact tech stack
- Real hands-on supply chain security experience (PR #384)
- Passion for security education, not just task completion

Project Timeline

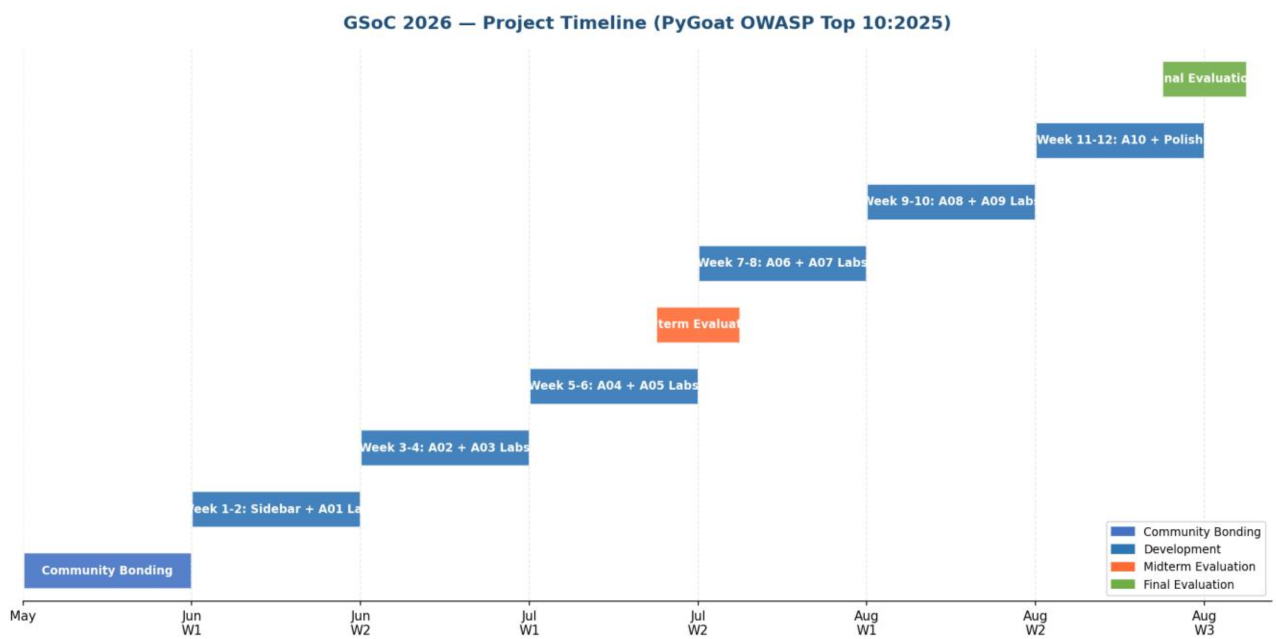

Figure 2: GSoC 2026 Project Timeline — 12 weeks and Community Bonding

Detailed Weekly Plan

Period	Deliverables
Community Bonding (May)	Deep dive into codebase, finalize lab designs with mentor, set up CI/CD
Week 1-2 (Jun 1-14)	Complete OWASP 2025 sidebar UI and A01: Broken Access Control interactive lab
Week 3-4 (Jun 15-28)	A02: Security Misconfiguration and A03: Software Supply Chain (codecov lab)

Week 5-6 (Jun 29-Jul 12)	A04: Cryptographic Failures and A05: Injection | Midterm Evaluation
Week 7-8 (Jul 13-26)	A06: Insecure Design and A07: Authentication Failures labs
Week 9-10 (Jul 27-Aug 9)	A08: Vulnerable Components and A09: Logging and Monitoring labs
Week 11-12 (Aug 10-24)	A10: Mishandling Exceptions and Documentation and Testing | Final Evaluation

Time Investment

- Before GSoC: Already contributing — PRs submitted, project set up, mentor contacted
- During GSoC: 40 or more hours per week, full commitment for 12 weeks
- After GSoC: Continue maintaining OWASP 2025 section and adding advanced labs

6. Prior Contributions

- **OWASP Python-Honeypot PR 384:** Security fix with full CVE analysis — github.com/OWASP/Python-Honeypot/pull/384
- **PyGoat Issue 490:** OWASP Top 10:2025 feature request — github.com/adeyosemanputra/pygoat/issues/490
- **PyGoat PR:** Added OWASP Top 10:2025 sidebar and 10 vulnerability info pages (A1 to A10)

7. Commitment

- Weekly communication with mentor on OWASP Slack in project-pygoat channel
- Regular commits with clear and descriptive messages
- Documentation written alongside code — not as an afterthought
- Responsive to mentor feedback and fast iteration
- Weekly progress reports throughout GSoC
- Continue contributing to PyGoat after GSoC ends

Thank you for considering my application. I am genuinely excited to contribute to OWASP PyGoat and help build the most current security education resource for the community.